PROMPT INJECTION THREAT ANALYSIS

Cova Funds

AI Security Threat Analysis

Prepared by

Nancy Okereke

Cybersecurity Analyst | GRC | Threat Analysis

1. Executive Summary

This report presents a prompt injection threat analysis conducted for Cova Funds, assessing the risk posed by prompt injection attacks against the organisation's AI-powered systems. As Cova Funds deploys AI across customer service, fraud detection, and loan decisioning, prompt injection represents a material and underappreciated attack vector that could result in data exposure, financial loss, and regulatory non-compliance.

Three attack scenarios were assessed. The customer service chatbot manipulation was rated Critical (Risk Score: 9). Fraud detection bypass and loan decisioning manipulation were each rated High (Risk Score: 6). This report documents the threat, provides analyst observations from hands-on testing, and recommends preventive, detective, and corrective controls for each scenario.

2. Scope and Methodology

Organisation	Cova Funds (fictional)
Threat Category	Prompt Injection — AI Security
AI Systems in Scope	Customer service chatbot, fraud detection system, loan decisioning tool
Testing Method	Hands-on prompt injection testing conducted via Gandalf by Lakera, a purpose-built AI security challenge environment
Risk Scoring	Likelihood x Impact (1–3 scale), maximum score 9
Date	February 2026

3. Analyst Observations

Prompt injection techniques were tested in a controlled environment using Gandalf by Lakera, a progressive AI security challenge designed to simulate real-world prompt injection scenarios. The following observations were recorded:

3.1 Effective Attack Techniques

- Hypothetical framing — presenting the extraction request as a thought experiment or fictional scenario successfully bypassed the AI's literal instruction filters at lower defence levels.
- Code-based obfuscation — encoding or reformatting the request in a non-standard structure circumvented keyword-based detection mechanisms.

3.2 Defence Escalation

- At Level 6, defences shifted from simple keyword blocking to semantic filtering — the AI began evaluating the intent of a request rather than matching specific words such as 'password', 'secret', or 'protect'.
- This transition represents a significant increase in defensive sophistication, requiring attackers to adopt more complex manipulation strategies to succeed.

3.3 Overall Assessment

- Prompt injection requires minimal technical skill — no coding or specialised tools are needed. Language manipulation alone is sufficient to execute an attack against inadequately defended AI systems.
- Direct instruction override was ineffective at higher defence levels, indicating that system prompt hardening provides meaningful resistance against straightforward attack attempts.
- The primary risk lies in AI systems with immature or keyword-only defences, which remain highly susceptible to hypothetical framing and obfuscation techniques.

4. Attack Scenarios

The following scenarios assess how prompt injection could be weaponised against Cova Funds' AI systems in a real-world context.

4.1 Customer Service Chatbot Manipulation

Attack Vector	Direct prompt injection via customer-facing chatbot interface
Attack Method	Attacker submits crafted messages using hypothetical framing or obfuscated instructions to override the chatbot's intended behaviour.
Potential Impact	Unauthorised disclosure of other customers' account information; fraudulent refund or transaction confirmations; redirection of users to phishing sites; reputational damage and regulatory exposure under NDPC.
Attacker Skill Required	Low — requires only language manipulation, no technical tools

4.2 Fraud Detection Bypass

Attack Vector	Indirect prompt injection via manipulated transaction data
Attack Method	Attacker crafts transactions with embedded adversarial inputs designed to manipulate the fraud detection model into misclassifying fraudulent activity as legitimate.
Potential Impact	Fraudulent transactions approved and processed; direct financial loss to Cova Funds and its customers; regulatory scrutiny from CBN if systemic fraud controls are found to be inadequate.
Attacker Skill Required	Medium — requires understanding of AI model behaviour and iterative testing

4.3 Loan Decisioning Manipulation

Attack Vector	Indirect prompt injection via documents submitted during loan application
Attack Method	Attacker embeds hidden instructions within submitted documents such as bank statements or identification documents. When processed by the AI loan decisioning tool, the instructions manipulate the model into approving a loan it should have rejected.
Potential Impact	Fraudulent loan approvals resulting in direct financial loss; compliance violations if AI decisioning lacks adequate human oversight; potential CBN regulatory action.
Attacker Skill Required	Medium — requires knowledge of document processing pipelines and AI input handling

5. Risk Assessment

Scenario	Likelihood	Impact	Risk Score	Priority
Chatbot manipulation	3	3	9	**Critical**
Fraud detection bypass	2	3	6	**High**
Loan decisioning manipulation	2	3	6	**High**

Likelihood and Impact scored on a 1–3 scale. Risk Score = Likelihood x Impact (maximum 9).

6. Recommended Controls

6.1 Chatbot Manipulation (Critical)

Control Type	Recommended Action
Preventive	Implement semantic input validation and output filtering to detect and block prompt injection attempts based on intent, not just keywords. Apply the principle of least privilege to chatbot permissions — the chatbot should only have access to data it needs to answer customer queries.
Detective	Monitor all chatbot conversations in real time for anomalous outputs, policy violations, or unexpected data disclosures. Log all interactions for post-incident review.
Corrective	Automatically suspend and escalate chatbot sessions upon detection of a prompt injection attempt. Conduct a full review of affected conversations and notify impacted customers if data was exposed.

6.2 Fraud Detection Bypass (High)

Control Type	Recommended Action
Preventive	Apply adversarial training techniques to harden the fraud detection model against manipulated inputs. Enforce strict data validation and sanitisation on all transaction inputs before they reach the AI system.
Detective	Implement a secondary rule-based fraud detection layer operating independently of the AI model. Flag any transactions where AI and rule-based assessments conflict significantly for mandatory human review.
Corrective	Automatically freeze transactions flagged as potentially manipulated pending manual review. Conduct a model audit to identify adversarial patterns and retrain the model accordingly after any confirmed bypass.

6.3 Loan Decisioning Manipulation (High)

Control Type	Recommended Action
Preventive	Sanitise and strip all submitted documents before processing by the AI system to neutralise embedded instructions. Enforce mandatory human approval for all loan decisions above a defined threshold, regardless of AI recommendation.
Detective	Maintain full audit logs of all AI loan decisions. Flag and escalate applications where AI recommendations conflict significantly with traditional credit scoring outputs.
Corrective	Immediately suspend AI-assisted loan processing upon confirmed manipulation. Review and reverse fraudulent approvals. Report the incident to relevant regulators and retrain the model on identified adversarial inputs.

7. Conclusion

Prompt injection represents a significant and growing threat to organisations deploying AI systems, particularly in high-stakes environments such as financial services. For Cova Funds, the customer service chatbot presents the most immediate risk given its public accessibility and low barrier to attack. Fraud detection and loan decisioning systems, while requiring greater attacker sophistication, carry equally severe business consequences if successfully compromised.

Hands-on testing confirmed that prompt injection attacks require minimal technical skill and can be executed using language manipulation alone against inadequately defended systems. Cova Funds is strongly advised to implement the controls outlined in this report, adopt semantic filtering over keyword-based defences, and establish ongoing AI security monitoring as a core component of its cybersecurity programme.